

Simulazione Spear-Phishing & Adversarial AI: Tecniche di Attacco e Strategie di Difesa

Nicola Madonna

17 Luglio 2026

1. Sintesi

Il presente documento descrive un esercizio pratico di Cyber Security incentrato sul cracking delle autenticazioni di servizi di rete tramite il software Hydra. L'attività è suddivisa in due fasi: nella prima viene configurato e testato un servizio SSH su Kali Linux, per poi eseguire un attacco a dizionario con Hydra al fine di recuperare le credenziali dell'utente creato. Nella seconda fase viene configurato un ulteriore servizio di rete (FTP) e viene replicata la procedura di cracking, con l'obiettivo di consolidare le competenze sia nella gestione dei servizi sia nell'utilizzo di Hydra per attività di verifica della sicurezza.

2. Introduzione

Il cracking delle password è una pratica utilizzata nell'ambito della cybersecurity per valutare la robustezza dei meccanismi di autenticazione. Attraverso tecniche come il brute-force e gli attacchi a dizionario, è possibile verificare quanto una password sia vulnerabile a tentativi sistematici di indovinamento. Questo tipo di analisi è fondamentale perché dimostra che password deboli o facilmente intuibili possono essere compromesse in tempi molto brevi, soprattutto quando vengono utilizzate wordlist comuni o strumenti automatizzati come Hydra.

L'esercitazione evidenzia inoltre un principio essenziale della sicurezza informatica: con sufficiente tempo, potenza computazionale e liste di password adeguate, qualsiasi credenziale può essere individuata. Per questo motivo è indispensabile adottare password complesse, lunghe e non presenti nei dizionari pubblici, così da ridurre drasticamente la probabilità di compromissione. L'attività svolta permette di comprendere sia le tecniche di cracking sia l'importanza delle buone pratiche nella gestione delle credenziali.

3. Obiettivi

L'obiettivo della prova pratica è quello di testare il cracking delle password. Utilizzeremo due configurazioni di servizi di rete per verificare come strumenti automatizzati possano individuare credenziali deboli. Vedremo in particolare:

- il servizio **SSH**, utilizzato per l'accesso remoto sicuro ai sistemi;
- il servizio **FTP**, utilizzato per il trasferimento di file tra macchine.

4. Cracking utilizzando il Servizio SSH

In questa sezione viene illustrato il processo di configurazione del servizio SSH e la successiva fase di attacco a forza bruta tramite lo strumento *Hydra*.

4.1. Configurazione Servizio SSH

Al fine di utilizzare il servizio SSH, sono state eseguite le seguenti operazioni Figura 1 .

Figura 1: Comandi per la configurazione del servizio SSH



```
kali@kali:~$ sudo adduser test_user
[sudo] password for kali:
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for test_user
Enter the new value, or press ENTER for the default
  Full Name []:
    Room Number []:
      Work Phone []:
        Home Phone []:
          Other []:
Is the information correct? [Y/n] y

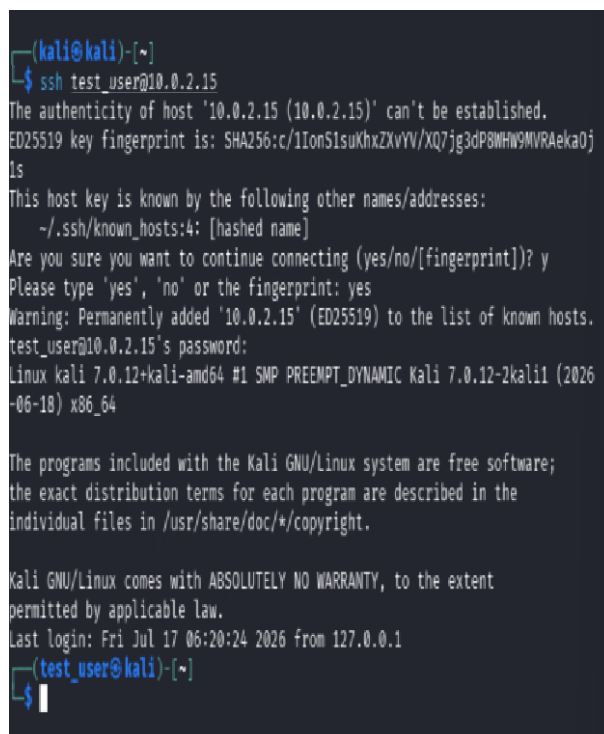
kali@kali:~$ sudo service ssh start

kali@kali:~$ sudo service ssh status
● ssh.service - OpenSSH Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset: disabled)
   Active: active (running) since Fri 2020-07-17 06:14:13 EUT; 20s ago
  Invocation: 04077a33942109230650754f9d8
    Docs: man:ssh(8)
          man:ssh_config(5)
   Process: 83700 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
    Main PID: 83706 (sshd)
      Tasks: 1 (limit: 4447)
    Memory: 2.2M (peak: 2.9M)
       CPU: 25ms
   CGroup: /system.slice/ssh.service
           └─sshd: "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

Jul 17 06:14:13 kali systemd[1]: Starting ssh.service - OpenSSH Secure Shell server ...
Jul 17 06:14:13 kali sshd[83706]: Server listening on 0.0.0.0 port 22.
Jul 17 06:14:13 kali sshd[83706]: Server listening on :: port 22.
Jul 17 06:14:13 kali systemd[1]: Started ssh.service - OpenSSH Secure Shell server.
```

Utilizzando il comando **ip a** è stato trovato l'ip e ; successivamente, è stato avviato il servizio SSH Figura 2.

Figura 2: Avvio del servizio SSH



```
kali@kali:~$ ssh test_user@10.0.2.15
The authenticity of host '10.0.2.15 (10.0.2.15)' can't be established.
ED25519 key fingerprint is: SHA256:c/1IonS1suKhxZXvYV/XQ7jg3dP8WHW9MVRaeka0j
1s
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:4: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '10.0.2.15' (ED25519) to the list of known hosts.
test_user@10.0.2.15's password:
Linux kali 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Jul 17 06:20:24 2026 from 127.0.0.1
test_user@kali:~$
```

4.2. utilizzo del tool Seclist e Hydra

Per ottimizzare il processo di recupero delle credenziali (username e password) è stato utilizzato il tool *SecLists*, che mette a disposizione estese raccolte di possibili combinazioni comunemente impiegate dagli utenti. Tuttavia, la ricerca all'interno di liste di grandi dimensioni può risultare estremamente lenta.

Per ridurre i tempi di individuazione delle credenziali è stato impiegato il comando `grep` Figura 3, che ha permesso di localizzare rapidamente all'interno delle wordlist sia l'username `test_user` sia la password `testpass`.

Figura 3: Utilizzo del tool grep

```
(test_user@kali) ~  
$ sudo grep -R "test_user" /usr/share/seclists/Usernames/  
[sudo] password for test_user:  
/usr/share/seclists/Usernames/HoneyPot-Captures/multiplatform-users-fabian-fingerle.de.txt:test_user  
/usr/share/seclists/Usernames/xato-net-10-million-usernames.txt:test_user  
/usr/share/seclists/Usernames/xato-net-10-million-usernames.txt:test_user1  
/usr/share/seclists/Usernames/xato-net-10-million-usernames.dup:test_user  
  
(test_user@kali) ~  
$ sudo grep "testpass" /usr/share/seclists/Passwords/*.txt  
/usr/share/seclists/Passwords/Most-Popular-Letter-Passes.txt:ess.txt:testpass  
/usr/share/seclists/Passwords/mssql-passwords-nanshou-guardicore.txt:testpassword  
/usr/share/seclists/Passwords/openwall.net-all.txt:testpass  
/usr/share/seclists/Passwords/scraped-JWT-secrets.txt:testpass  
/usr/share/seclists/Passwords/scraped-JWT-secrets.txt:testpassphrase
```

Una volta identificato il file contenente le credenziali, esso è stato modificato manualmente: l'username `test_user` e la password `testpass` sono stati identificati nel file tramite `ctrl+w` Figura 4 e `test_user` è stato spostato in cima, mentre `testpass` è stata collocata in una posizione intermedia, comunque sufficientemente vicina all'inizio da velocizzare l'attacco. Questa operazione ha permesso di ridurre drasticamente il numero di tentativi necessari da parte di *Hydra*, rendendo l'attacco più rapido ed efficiente.

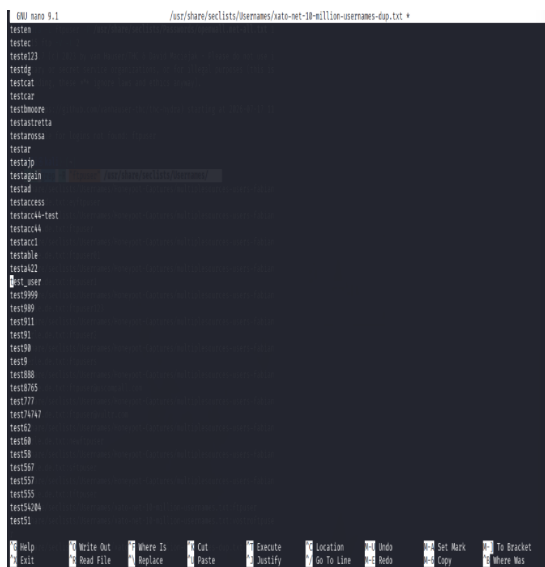


Figura 4: Ricerca dell'username `test_user`

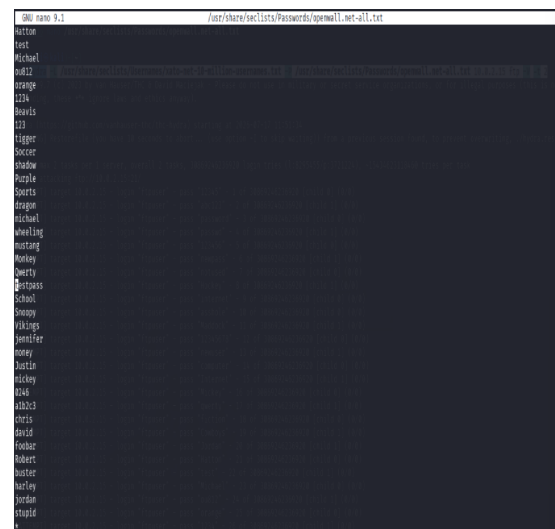


Figura 5: Ricerca della password `testpass`

Figura 6: Confronto tra ricerca di username e password nelle wordlist SecLists

Successivamente, è stato eseguito l'attacco a forza bruta tramite *Hydra*, che ha correttamente individuato le credenziali presenti nella wordlist modificata.

5. Cracking utilizzando il Servizio FTP

5.1. Attacco al servizio FTP

La seconda parte dell'esercizio è speculare alla prima, con la differenza che l'analisi e l'attacco a forza bruta sono stati eseguiti sul servizio *FTP*. Anche in questo caso è stato configurato il servizio FTP sul sistema.

Come nella fase precedente, è stato utilizzato il tool *SecLists* per individuare rapidamente le credenziali all'interno delle wordlist pubbliche. Tramite il comando **grep** sono stati ricercati sia l'username sia la password, verificando la loro presenza nelle liste più comuni. Per ridurre i tempi di attacco, il file contenente le credenziali è stato modificato manualmente: l'username è stato spostato in cima alla lista, mentre la password è stata collocata in una posizione vicina, così da diminuire il numero di tentativi necessari.

Una volta preparate le wordlist, è stato eseguito l'attacco a forza bruta tramite *Hydra* Figura 7, che ha correttamente individuato le credenziali FTP.

Figura 7: Individuazione di username e password tramite hydra

```
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass 'chris' - 50 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass 'david' - 51 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass 'foobar' - 52 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass 'Robert' - 53 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass 'buster' - 54 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass 'harley' - 55 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass 'jordan' - 56 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass 'stupid' - 57 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass '*' - 58 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass 'apple' - 59 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass 'fred' - 60 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass '123abc' - 61 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass 'Amanda' - 62 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass 'Dakota' - 63 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass 'summer' - 64 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'ftpuser' - pass 'ftppassword' - 65 of 30869262827830 [child 0] (0/0)
[22][ssh] host: 10.0.2.15 login: ftpuser password: ftpassword
[ATTEMPT] target 10.0.2.15 - login 'info' - pass '12345' - 3721227 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'abc123' - 3721228 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'password' - 3721229 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'passwd' - 3721230 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass '123456' - 3721231 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'newpass' - 3721232 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'notused' - 3721233 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'Hockey' - 3721234 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'internet' - 3721235 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'asshole' - 3721236 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'Maddock' - 3721237 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass '12345678' - 3721238 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'newuser' - 3721239 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'computer' - 3721240 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'Internet' - 3721241 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'Mickey' - 3721242 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'qwerty' - 3721243 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'fiction' - 3721244 of 30869262827830 [child 1] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'Cowboys' - 3721245 of 30869262827830 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login 'info' - pass 'Jordan' - 3721246 of 30869262827830 [child 1] (0/0)
The session file ./hydra.restore was written. Type 'hydra -R' to resume session.
```

6. Conclusioni

L'attività svolta ha permesso di analizzare in modo pratico le dinamiche legate alla sicurezza dei servizi di autenticazione remota, in particolare SSH e FTP. In entrambi i casi è stato possibile osservare come l'utilizzo di credenziali deboli o presenti all'interno di wordlist pubbliche renda il sistema vulnerabile ad attacchi a forza bruta automatizzati.

L'impiego del tool *SecLists* ha evidenziato quanto sia semplice, per un attaccante, verificare la presenza di username e password comuni all'interno di raccolte facilmente reperibili online. L'uso del comando **grep** ha ulteriormente velocizzato il processo di individuazione delle credenziali, dimostrando come un'analisi preliminare delle wordlist possa ridurre significativamente i tempi necessari per un attacco.

La fase di attacco, eseguita tramite *Hydra*, ha confermato la vulnerabilità dei servizi quando

protetti da credenziali non adeguate. In entrambi gli scenari, SSH e FTP, Hydra è stato in grado di recuperare le credenziali modificate nelle wordlist, evidenziando l'importanza di adottare password robuste, non presenti in raccolte pubbliche e difficili da indovinare tramite tentativi automatizzati.

In conclusione, l'esercitazione ha mostrato in modo chiaro come la sicurezza dei servizi di autenticazione dipenda fortemente dalla qualità delle credenziali scelte e dalla consapevolezza dei rischi associati all'utilizzo di password deboli. Una corretta gestione delle password, unitamente a misure di protezione aggiuntive, rappresenta un elemento fondamentale per garantire la sicurezza dei sistemi esposti in rete.